

CargoExpress PH — Findings Verification Report

Review type: Independent, read-only QA audit of SYSTEM_FLOW_AND_LOGIC_REVIEW.md **Baseline commit:** 8ea48e9739e7ac3d35653b98406d54da695aae89 on main (2026-09-18, post-deployment status check) **Scope:** Verification of QA findings using source-contract analysis and automated PGLite database tests.

Verification Summary Table

#	Original Finding	Evidence Checked	Test / Reproduction Result
1	Financial example misrepresents the user's scenario	§4.3 of report vs. user's exact numbers	The correct two-refund scenario was buried in a footnote.
2	get_sales_overview_data() bucketing bug	PGLite regression test (scripts/sales-overview-regression-pgtest/run.mjs)	Pre-fix Reproduction: Confirmed SQL mismatch; duplicate updates shifted refund months. Post-fix Result: 5/5 assertions passed. Migration 20260919030000_fix_sales_overview_refund_period.sql is confirmed applied in the remote history.
3	Retroactive repricing of weighed-but-untripped orders	PGLite execution test checking orders_trip_required_for_active_status constraint	Disproven. The missing trip_id check in the pickup RPC is moot. An order cannot reach status='Picked Up' with trip_id=NULL due to the database CHECK constraint. The bug is structurally unreachable.
4	Customer can rewrite admin chat message content	Source code inspection of guard_chat_message_update AND PGLite execution test (scripts/chat-protection-pgtest/run.mjs)	Disproven. Trigger explicitly checks for content changes. Authenticated execution evidence shows that marking an owned conversation's message as read succeeds, editing content fails (throws 42501), and updating another customer's conversation fails.
5	Password/email change doesn't invalidate other sessions	AuthContext.jsx inspection	Confirmed gap in code. No signOut({ scope: 'others' }) call exists. Server-side refresh-token revocation behavior on password change is UNVERIFIED.
6	Activity-log retry queue survives logout	AuthContext.jsx inspection	Confirmed. clearSupabaseAuthStorage() only removes sb-* keys. Key cargoexpress.activity-log.queue.v1 survives.

Detailed Updates

1. Retroactive Repricing: Bug is Blocked

The original report classified the retroactive repricing bug as "Confirmed Reachable Bug". Execution testing proves this was incorrect. While the RPC record_pickup_payment does not check for a trip_id, attempting to move an order to status = 'Picked Up' without a trip immediately triggers a constraint violation: orders_trip_required_for_active_status. Even SECURITY DEFINER functions bypass RLS but cannot bypass table-level CHECK constraints. The bug is dead-on-arrival.

2. Sales Overview Refund Date: Fixed

- Pre-fix Reproduction:** Confirmed that updated_at drift caused the reporting RPC to bucket refunds in the wrong month.
- Migration Applied:** 20260919030000_fix_sales_overview_refund_period.sql safely implemented COALESCE(succeeded_at, provider_updated_at, updated_at).
- Post-fix Test Results:** Regression tests passed successfully. The RPC now correctly binds the event date to the immutable succeeded_at timestamp.

3. Chat Protection: Verified Secure

- Source Protection:** 20260831070000_secure_cancellation_and_chat_updates.sql establishes a robust BEFORE UPDATE trigger on chat_messages that explicitly prevents modifications to the message content by customers.
- Authenticated Execution Evidence:** Using the chat-protection-pgtest test file running an authenticated user role, we proved:
 - A customer can mark their own admin messages as read (is_read = true).
 - A customer attempting to update the message text throws an insufficient privilege error (42501).
 - A customer cannot modify messages in another customer's conversation.